

Glossary for Non-Technical Readers

A companion to *Quantifying Compromise Risk in Exceptional Access Architectures Under Sparse and Indirect Evidence*

Alan Woodward
Surrey Centre for Cyber Security, University of Surrey

2026

This glossary explains the technical vocabulary, cryptographic concepts, statistical methods, and modelling choices used in the paper. It is organised into five parts: (1) the policy and architectural setting, (2) the cybersecurity vocabulary, (3) the historical incidents that motivate the analysis, (4) the statistical and mathematical methods, and (5) the modelling-specific concepts and why we use the methods we do.

The paper, the reproducibility code, and an interactive browser-based version of the risk model are available at <https://github.com/profwoodward/EA-Risk-Model-Tool>.

1 The Policy and Architectural Setting

Exceptional Access (EA)

A general term covering any technical mechanism that allows an authorised third party—typically a law-enforcement or security agency—to obtain the contents of communications or stored data that would otherwise be protected by encryption. EA does not refer to a single technology but to a family of architectures including key escrow, key recovery, server-side decryption mandates, and “ghost user” proposals. The central security concern is that any such mechanism necessarily creates an alternative path to protected data, and that path is itself a target.

End-to-End Encryption (E2EE)

An encryption scheme in which only the communicating endpoints (the two phones in a conversation, for example) hold the keys necessary to decrypt the content. Intermediate parties—including the messaging platform itself—cannot read the content even if they hold the encrypted data. EA mandates are, in essence, requirements that operators retain some technical means of bypassing E2EE under defined conditions.

Transmission-Layer EA (T-EA)

EA implemented inside the carrier’s network infrastructure, so that traffic in transit can be intercepted at the operator’s switching equipment. The classic example is CALEA in the United States, which mandates that telecommunications carriers maintain interception capability. In T-EA, the cryptographic keys and the encrypted traffic naturally flow through the same physical equipment—they are *co-located*, in the paper’s terminology—which means that a single compromise of the intercept infrastructure exposes both.

Over-the-Top EA (OTT-EA)

EA implemented at the level of the messaging or storage platform, rather than the underlying network. The platform operator (rather than the network carrier) is required either to

retain keying material or to perform server-side decryption on demand. The Levy–Robinson “ghost user” proposal is the canonical example. In OTT-EA, the keys can in principle be held in different infrastructure from the encrypted message storage—they are *architecturally segregated*—and this segregation is the structural feature that distinguishes the OTT-EA risk profile from the T-EA one.

CALEA

The U.S. Communications Assistance for Law Enforcement Act (1994). It requires telecommunications carriers to design their networks so that lawful intercept is technically possible. The Salt Typhoon incident of 2024 demonstrated that the very intercept infrastructure mandated by CALEA can itself be compromised by a foreign adversary.

Client-Side Scanning (CSS)

A hybrid architecture in which the user’s own device (rather than a server) scans messages or stored files for prohibited content before they are encrypted, using detection rules supplied by the operator. The EU “Chat Control” proposals are the leading example. The paper treats CSS only qualitatively because it combines operator-side risk (similar to OTT-EA) with risks on the user’s device that the paper’s empirical anchors do not directly cover. The paper’s qualitative treatment, however, is not neutral on its risk profile: every structural observation in the supplementary material’s CSS analysis (Supplementary Section S18) runs against CSS relative to OTT-EA. CSS enlarges the cross-cutting attack surface (the mobile platform itself becomes shared infrastructure between detection-key custody and endpoint scanning), introduces compromise modes absent from T-EA and OTT-EA (device-level malware, platform update-infrastructure compromise, user-level evasion), and would, on the structural argument, produce a heavier upper tail than OTT-EA. The precautionary policy posture the paper recommends is to treat CSS as carrying *at least* the OTT-EA risk profile, with material additional risk from the endpoint-distribution component.

Threshold Scheme (Distributed EA)

An architecture in which the cryptographic key is mathematically split into several pieces (“shares”) held by different independent trustees, with the rule that some specified minimum number of them—say five out of nine—must cooperate to reconstruct the key. This removes the “single trusted operator” property that characterises both T-EA and OTT-EA, and the paper shows it can reduce risk by orders of magnitude (provided the shareholders fail independently). Apple’s Cloud Key Vault uses a related construction.

Architectural Segregation

A property of a system, expressed as a number s between 0 and 1. It captures the degree to which the cryptographic keys and the encrypted data are kept in *separate* infrastructure with separate access controls. $s = 0$ means keys and data are in the same place (T-EA). s close to 1 means they are well separated, so that compromising the keys does not automatically compromise the data (well-designed OTT-EA). The “segregation gain” is the resulting reduction in risk.

Cross-Cutting Infrastructure

Components that sit between the key-side and data-side of an architecturally segregated system and that, if compromised, give the attacker access to *both*. Shared identity providers, shared build pipelines, and credentials held by privileged engineers who can touch both subsystems are typical examples. Cross-cutting infrastructure is the structural reason why segregation alone does not eliminate risk: a single well-chosen compromise can collapse the segregation.

Compromise Definitions (Technical, Data, Operational, Access-Pathway)

The paper distinguishes four kinds of “compromise” because under architectural segregation

they are no longer equivalent:

- **Technical compromise**—an attacker has obtained the cryptographic keys but not the encrypted data.
- **Data compromise**—an attacker has obtained the encrypted data but not the keys.
- **Operational compromise**—the attacker has obtained *both* and can therefore decrypt target communications. This is the policy-relevant outcome.
- **Access-pathway compromise**—the attacker has obtained the ability to issue interception requests through the system’s normal channels (a different problem from key theft, and one that abuses the system’s authorised-access mechanism rather than breaking it).

In T-EA these largely collapse into one another. In OTT-EA they are genuinely distinct, which is why the paper takes care to define them separately.

Operational Viability

A formal constraint the paper imposes on the architectural decomposition in Pillar III: an EA system is operationally viable only if it can discharge its legal mandate end-to-end—process authorised lawful-intercept requests, maintain audit records, operate continuously, and be staffed and maintained across a multi-year deployment. The constraint rules out “zero-risk” specifications that would eliminate a risk channel only at the cost of making the system unable to function as an EA system at all. The four non-eliminable risk channels of Pillar III (insider, zero-day, supply chain, operational error) are non-eliminable precisely *because* removing any of them would breach operational viability.

2 Cybersecurity Vocabulary

Hardware Security Module (HSM)

A specialised, tamper-resistant piece of hardware whose sole purpose is to hold cryptographic keys and perform cryptographic operations *without* the keys ever leaving the device in plaintext. Banks, certificate authorities, and high-security operators use HSMs because compromising one requires either physical access plus expertise or a flaw in the firmware. FIPS 140-3 Level 4 is the highest formal certification level.

Key Escrow

Any arrangement under which a copy of cryptographic keys (or material that can reconstruct them) is held by a third party for later retrieval—historically the prototypical EA mechanism. The Clipper Chip of the 1990s is the textbook example.

Advanced Persistent Threat (APT)

The standard label for a sophisticated, well-resourced, and patient adversary—typically a nation-state or state-sponsored group. APTs differ from ordinary cybercriminals in three ways: their tooling (which often includes zero-day exploits), their patience (campaigns run for months or years), and their objectives (intelligence gathering rather than immediate financial gain). The paper’s “two-tier adversary model” splits attackers into APTs and the more numerous but less capable “opportunistic” actors.

Insider Threat

Risk arising from people who already have legitimate access to a system—employees, contractors, cleared personnel—and who misuse that access. Insider compromise can be malicious (Snowden, Vault 7), coerced, or simply careless. The paper treats insider threat as a non-eliminable risk channel because any operationally viable EA system must employ cleared personnel with privileged access.

Zero-Day Vulnerability

A software flaw not yet known to the vendor, and therefore unpatched. “Zero-day” refers to the number of days the defender has had to fix it. Zero-days are the highest-value capability for sophisticated adversaries, and the empirical evidence shows that EA-relevant components (HSM firmware, cryptographic libraries) appear in active zero-day exploitation lists.

Supply-Chain Attack

A compromise that reaches the target by way of one of its software or hardware suppliers, rather than by attacking the target directly. SolarWinds (2020) and the XZ Utils backdoor (2024) are the canonical examples. The paper treats supply-chain exposure as a non-eliminable channel because no operator can fully vertically integrate.

Certificate Authority (CA)

An organisation trusted to vouch for the cryptographic identity of websites and other entities by issuing digital certificates. CAs hold high-value private keys: if compromised, an attacker can impersonate any website. The paper uses the historical record of CA compromises (DigiNotar, Comodo, etc.) as Stream B because CAs are the closest historical analogue to a centralised single-operator key custodian.

Lawful Intercept

The legally authorised real-time interception of communications, distinct from after-the-fact data requests. T-EA infrastructure exists precisely to enable lawful intercept.

EPSS, MITRE ATT&CK, DBIR, M-Trends, CISA—the empirical sources

The paper draws its scenario parameters from several public data sources:

- **EPSS (Exploit Prediction Scoring System)**—an open framework that assigns each known software vulnerability a probability of being exploited in the next thirty days. Used to set realistic baselines for the likelihood that an opportunistic attacker can use any particular vulnerability.
- **MITRE ATT&CK**—a public catalogue of documented adversary techniques, organised into a matrix. Used to map abstract attack scenarios onto specific real-world techniques whose frequency can be estimated.
- **Verizon DBIR (Data Breach Investigations Report)**—an annual statistical report on the year’s breaches. Used for breach-frequency baselines.
- **Mandiant M-Trends**—an annual report from a major incident-response firm; used here for technique-specific “uplift factors” describing how much more often APTs use a given technique than ordinary criminals.
- **CISA (Cybersecurity and Infrastructure Security Agency)**—the U.S. federal cybersecurity coordinating body. Its joint advisories are used as primary documentation for state-sponsored campaigns.

NCSC, Dstl, the Five Eyes

Policy-facing readers will recognise these. The UK National Cyber Security Centre is the part of GCHQ that handles defensive cybersecurity guidance; Dstl is the MoD’s research arm; the Five Eyes are the intelligence-sharing partnership of the UK, US, Canada, Australia, and New Zealand whose combined position on EA shapes the international debate.

3 Historical Incidents

These are the real-world events the paper uses both to make the threat concrete and to calibrate parameters. Examples include:

Salt Typhoon (2024)

A Chinese state-sponsored campaign that compromised the CALEA-mandated lawful-intercept systems of nine or more U.S. telecommunications carriers. The attackers obtained the active wiretap target list, meaning they could see exactly whom the U.S. government was monitoring. Salt Typhoon is the most direct possible demonstration that EA infrastructure is itself a high-priority intelligence target.

Athens Affair (2004–05)

Malicious software was installed on lawful-intercept equipment in Vodafone Greece, allowing surveillance of more than 100 senior Greek government officials, including the Prime Minister, during the Athens Olympics. Notable because the attackers used the system’s *legitimate* lawful-intercept capability—they did not break the encryption, they used the back-door it provided.

Crypto AG / Operation Rubicon

A Swiss firm that sold cryptographic equipment to over 100 governments was, from the 1970s to 2018, secretly co-owned by the CIA and the German BND. The cipher devices it sold were deliberately weakened, allowing the U.S. and Germany to read foreign government communications for decades. Declassified in 2020. The lesson is that the cryptographic infrastructure itself can be the covert channel.

Storm-0558 (2023)

A Chinese state actor obtained a Microsoft consumer signing key and used it to forge authentication tokens for Outlook Web Access, gaining access to email accounts of U.S. State Department officials and others. The closest empirical analogue to an OTT-EA-style compromise: the attacker did not break encryption, they obtained the master key.

LastPass (2022)

A two-stage attack on the password-manager LastPass: the attackers first stole source code, then used what they learned to exfiltrate customers’ encrypted password vaults. Illustrates the multi-stage compromise pattern characteristic of platform-level (OTT-leaning) attacks.

Microsoft Midnight Blizzard (2024)

A Russian state actor (the same group responsible for SolarWinds) used password-spray and OAuth abuse to access Microsoft corporate email and source code. Demonstrates persistent state-level targeting of trusted infrastructure operators.

DigiNotar (2011)

A Dutch Certificate Authority was fully compromised; the attacker issued roughly 500 fraudulent certificates including for Google domains, then used them to surveil Iranian users. DigiNotar was distrusted by every major browser and went bankrupt. The clearest historical demonstration that compromising a single trusted key custodian can affect millions of users.

4 Statistical and Mathematical Methods

This section explains both *what* each method is and *why* it is used here.

4.1 Probability and Distributions: the Building Blocks

Probability Distribution (in plain terms)

A description of how likely each possible value of an uncertain quantity is. The paper repeatedly speaks of “the distribution of annual compromise probability”—meaning that, rather than committing to a single number, the analysis produces a curve showing the relative likelihood of every value the true risk might take.

Bernoulli, Binomial, Poisson

Three foundational distributions for counting events:

- **Bernoulli**—the distribution of a single yes/no event with probability p .
- **Binomial**—the count of successes in a fixed number of independent Bernoulli trials.
- **Poisson**—the count of events in a fixed period when events occur independently at a constant average rate. Used throughout the paper for breach counts: if breaches occur at rate λ per year, the Poisson distribution describes how many we would see in any given year.

Beta, Gamma, Log-Normal, Half-Normal—the Priors

These are families of probability distributions used as “priors”—formal representations of what we believe before seeing data. The paper picks each of these for specific reasons:

- **Beta** distributions live on the interval $[0, 1]$ and are therefore the natural choice for probabilities (such as the EPSS exploitability score).
- **Gamma** distributions live on the positive real numbers and are the natural conjugate prior for Poisson rates—meaning that combining a Gamma prior with Poisson data gives an updated Gamma distribution in closed form, which is mathematically convenient.
- **Log-normal** distributions are right-skewed (their logarithms are normal); they are the standard choice for hazard rates in reliability engineering because rates are positive and often span several orders of magnitude.
- **Half-normal** distributions are the positive half of a normal distribution; used for non-negative quantities where we want to encode “small with some uncertainty”.

Generalised Pareto Distribution (GPD)

A distribution specifically designed to describe the tail of another distribution—that is, the upper end where extreme values live. The paper fits a GPD to the upper 10% of its simulated annual compromise probabilities. The shape parameter ξ is the headline number: $\xi > 0$ means a “heavy” tail decaying as a power law (extreme events are unusually common), $\xi = 0$ means an exponential tail, $\xi < 0$ means a bounded tail. Both the T-EA and OTT-EA distributions come out with $\xi > 0$ under the primary calibration, placing them in what extreme-value theorists call the *Fréchet domain*.

4.2 Frequentist Estimation: the Pillar I Tools

Maximum Likelihood Estimation (MLE)

The classical method: pick the parameter value that makes the observed data most likely. For a Poisson rate, the MLE is just the count of events divided by the exposure: Stream A’s headline rate is exactly this computation, 6 incidents over $50 \times 13 = 650$ system-years giving $\hat{\lambda} = 6/650 \approx 0.92\%/yr$. Simple, transparent, and well-suited to small datasets where more elaborate methods would overfit.

Garwood Exact Confidence Interval

A confidence interval for a Poisson rate that is “exact” in the technical sense of using the chi-squared distribution rather than a normal-approximation shortcut. The paper uses Garwood intervals throughout because the breach counts are small (single digits in some streams), and approximate intervals can be badly wrong at small k .

Confidence Interval vs Credible Interval—the Distinction Matters

A 95% **confidence interval** is a frequentist construct: across many hypothetical repetitions of the experiment, 95% of constructed intervals would contain the true value. It is *not* the probability that the true value lies in this particular interval. A 95% **credible interval** is a

Bayesian construct, and it *does* admit the natural reading: there is a 95% probability—given the prior and the data—that the true value lies in the stated range. The paper reports Garwood confidence intervals for the empirical streams (Pillar I) and credible intervals for the Bayesian layer (Layer IV); the distinction is preserved deliberately.

Survival Analysis

A family of statistical methods for analysing time-to-event data—originally developed for medical studies of patient survival, now standard in reliability engineering. The paper uses survival methods on Stream A to estimate “time to first breach” in the analogue cohort, which gives an alternative window onto the same underlying rate.

Bootstrap Resampling

A computational technique for estimating uncertainty by repeatedly resampling the observed data with replacement and recomputing the statistic of interest. Useful when the data are too messy or sparse for clean theoretical formulas, and used in Pillar I as one of several cross-checking methods.

Rule of Three (Zero-Event Estimator)

A useful rule of thumb: if you observe zero events in N trials, the upper 95% bound on the true rate is roughly $3/N$. The paper notes this in passing because some sub-cohorts have zero observed events, and the rule of three keeps such cases from being treated as “rate is exactly zero”.

Overdispersion Check (Stream B)

A Poisson model assumes the variance of annual incident counts equals their mean; “overdispersion” (variance exceeding the mean) would signal clustering that the Poisson model misses. The paper now reports this check explicitly for the 19-year Stream B count series: the dispersion statistic is 0.83 (slightly *under*-dispersed), the chi-squared dispersion test does not reject the Poisson model, and a negative binomial re-fit collapses back to the Poisson. With only 19 annual counts the test has limited power, which the paper says plainly—but the data show no evidence that the Poisson cohort machinery is the wrong tool.

4.3 Bayesian Methods: the Layer IV Machinery

Bayesian Inference (in plain terms)

A way of doing statistics in which beliefs about an unknown quantity are represented as a probability distribution that gets *updated* in light of data. Three core objects:

- **Prior**—what you believe before seeing data.
- **Likelihood**—how probable the observed data are under each possible value of the unknown.
- **Posterior**—the updated belief, combining the prior and the likelihood via Bayes’ theorem.

Prior Predictive Distribution—and Why This Paper Uses It

A specifically subtle point. *Posterior* inference requires data to update against. For a system that has never been deployed, there are no EA-specific compromise events to use. So the paper does *not* perform posterior inference; it performs **prior predictive** simulation, which means: sample from the prior, push the sampled parameters through the model, and see what distribution of outcomes results. The output describes “what we would predict, given everything we currently believe and the structure of the model”—and the honesty of the analysis depends on transparently disclosing where the priors came from. The paper does this in Section 8: the priors are calibrated *architecture-conditionally* against the architecturally-matched analogue empirical streams (T-EA priors from Streams A and B; OTT-EA priors from Streams B and C), so the Bayesian medians cannot be presented as independent corroboration of the empirical ranges they were calibrated to produce.

Hierarchical (Multi-level) Model

A Bayesian model in which parameters at one level are themselves drawn from distributions whose parameters are unknown. This allows the model to “pool” information across related but not identical settings. In this paper, edge hazard rates are drawn from log-normal distributions whose location and scale are themselves random—the hyperparameters—and the hyperpriors encode uncertainty about the analogical mapping from non-EA systems.

Conjugate Prior (Gamma–Poisson)

A prior is *conjugate* to a likelihood if combining them produces a posterior in the same family as the prior. The Gamma distribution is conjugate to the Poisson likelihood: if breaches arrive as $\text{Poisson}(\lambda)$ and the prior on λ is $\text{Gamma}(\alpha, \beta)$, the posterior is also Gamma. Used in Pillar I sensitivity analysis because it yields exact results without simulation.

Markov Chain Monte Carlo (MCMC) and the Gelman–Rubin Diagnostic

MCMC is the standard computational technique for Bayesian posterior inference: it constructs a chain of samples whose long-run distribution is the posterior. The Gelman–Rubin $\hat{R}$ statistic compares the variance *within* a chain to the variance *between* chains; values close to 1 indicate convergence. The paper notes that for prior predictive sampling—which is technically just independent draws— $\hat{R}$ values close to 1 are expected and trivial; they confirm only that the simulation is implemented correctly.

4.4 Stochastic Processes: How the Paper Models “Rate over Time”

Poisson Process (Homogeneous and Non-Homogeneous)

A model for events arriving randomly at some rate. *Homogeneous* means the rate is constant; *non-homogeneous* means the rate varies with time. The paper uses non-homogeneous Poisson processes because EA systems’ compromise rates may evolve over time in response to attacker capability growth, defensive degradation, and the like.

Hazard Rate

The instantaneous rate at which compromise events occur—for example, 0.05 events per system-year. Hazard rates are the natural “atomic” objects in reliability modelling. The paper assigns a hazard rate to each *edge* in its attack graph and aggregates them up into a system-level hazard.

Annual Compromise Probability (q_1)

The probability that a system suffers at least one successful compromise in a one-year period. If the underlying hazard rate is λ events/yr, then under a homogeneous Poisson process $q_1 = 1 - \exp(-\lambda)$. The paper’s headline three-pillar central values—7.3% (T-EA Pillar II) and 3.9% (OTT-EA Pillar II)—are q_1 values, as are the Bayesian medians (4.0% T-EA, 2.6% OTT-EA). The distinction between q_1 (annual) and Q_T (cumulative over T years; see below) matters because dependence between years can change the relationship between them.

Cumulative Compromise Probability (Q_T)

The probability that a system suffers at least one successful compromise over a horizon of T years. Under independence between years and constant rate, $Q_T = 1 - (1 - q_1)^T$, so Q_{10} at $q_1 = 4\%$ is about 34%. Under the full dependence model of Section 8, correlated campaigns raise the median ten-year cumulative probability from 26.6% (independence) to 36.6% for T-EA, and from 15.7% to 31.9% for OTT-EA—the OTT-EA cumulative risk roughly doubles when dependence is modelled rather than assumed away. Cumulative quantities are the policy-relevant ones because EA mandates have decadal time horizons.

Maximum Defensible Deployment Horizon (T^*)

The largest T such that the median predicted cumulative compromise probability Q_T stays

below an acceptability threshold τ . Under the full dependence model, a 5% threshold gives $T^* = 2$ years for both architectures; a 10% threshold gives year 3 (T-EA) versus year 4 (OTT-EA); a 20% threshold gives years 6 versus 9; a 30% threshold years 9 versus 14; and at a 50% threshold the gap widens to 17 versus 26 years. The OTT-EA horizons are *longer* at the median but the distribution around them is tail-heavier, so high-risk outcomes remain more plausible for OTT-EA—the apparent advantage at the centre is offset by greater uncertainty at the upper bound.

Latent Variable

An unobserved random variable that influences the observable outcomes. The paper introduces a latent “campaign intensity” $Z(t)$ that captures the (unobserved) level of coordinated adversarial activity in any given year. When Z is large, all attack channels are simultaneously more dangerous—capturing the way real-world APT campaigns work.

Copula (Gaussian, Gumbel)

A mathematical construction for separating the *marginal* distributions of several random variables (what each looks like on its own) from their *dependence structure* (how they move together). Different copulas encode different patterns of joint behaviour: Gaussian copulas have symmetric dependence with no extreme tail clustering; Gumbel copulas have heavier upper-tail dependence (events tend to be extreme together). The choice matters when modelling correlated campaigns: if attacks really do cluster in the worst cases, a Gaussian copula will *understate* tail risk.

4.5 Bounding and Aggregation Methods

Independence Assumption—and Why It’s Both Used and Warned About

“Independent” here means: knowing whether one attack channel succeeded gives no information about whether others succeeded. Under independence, the probability that *at least one* of several channels succeeds equals 1 minus the product of the per-channel failure probabilities—which is the formula used throughout Pillars I–III. Independence is mathematically convenient and produces tractable closed-form answers. However, real adversarial campaigns are *correlated*—a single APT may exploit multiple channels in a coordinated way—so the independence assumption tends to *understate tail risk*. The Bayesian model in Section 8 is specifically designed to relax the independence assumption and quantify the consequences. In the current calibration the inflation factor is $\times 1.53$ for the T-EA annual 95th percentile and $\times 2.83$ for OTT-EA; on the ten-year cumulative median the corresponding movement is from 26.6% to 36.6% (T-EA) and from 15.7% to 31.9% (OTT-EA). In every case OTT-EA is the more sensitive architecture, because correlated campaigns preferentially exploit the cross-cutting infrastructure that defines OTT platforms.

Two senses of “dependence” enter the analysis, and a careful policy reader needs to keep them apart. The first sense is *rate amplification under shared campaign intensity*: when an APT runs a coordinated operation, all edge hazard rates rise *simultaneously*, because adversary effort, tooling, and timing are shared across attack vectors. This is what the latent campaign variable $Z(t)$ in Layer IV models, and it is the realistic picture of how correlated adversaries actually behave. Under this sense, dropping independence *worsens* every policy-relevant number, with the worsening concentrated in the tail rather than the median and architecturally asymmetric (larger for OTT-EA than for T-EA). The second sense is *comonotonic correlation at fixed hazard rates*: events become perfectly synchronised in their outcomes but their individual probabilities are held constant. This is what the Fréchet–Hoeffding lower bound captures (see **Fréchet–Hoeffding Bounds**). Under this sense, the union probability collapses to the maximum individual rate—which can be *lower* than the independence-based estimate, because perfectly correlated success events are not double-counted. For policy purposes only

the first sense is the relevant one: real adversaries do not synchronise pre-existing fixed rates, they concentrate effort and elevate rates. The 2.2% Fréchet lower bound for T-EA and the 1.1% lower bound for OTT-EA are mathematically valid model-internal bounds but should not be misread as “what happens when independence fails”. What happens when independence fails—as a matter of empirical adversary behaviour—is what Layer IV reports.

Fréchet–Hoeffding Bounds

A pair of mathematical theorems that bound the probability of a union of events under *any* dependence structure between them *when the individual event probabilities are held fixed*. The lower bound (the “comonotonic” case) is when events are perfectly positively correlated; the upper bound (the “antitonic” case) corresponds to the events being as anti-correlated as possible. The paper uses Fréchet–Hoeffding bounds to express its model output as an interval—for T-EA, [2.2%, 7.5%]; for OTT-EA, [1.1%, 4.0%]—that is robust to *any* assumption about dependence within the seven-scenario model. This is a deliberately humble framing: rather than claim a single “true” number, the paper says “here is the range the model is consistent with, irrespective of how the channels happen to be correlated”.

Important interpretive caveat. The Fréchet–Hoeffding lower bound answers a different question from the Bayesian Layer IV dependence model. The lower bound holds individual hazard rates *fixed* and asks what happens when their realisations become perfectly synchronised; the answer is that the union probability collapses to the maximum individual rate. The Bayesian model, by contrast, asks what happens when shared campaign intensity drives all edge hazard rates *up simultaneously*; the answer is that the upper tail expands by a factor of $\times 1.53$ (T-EA) or $\times 2.83$ (OTT-EA). The two questions are distinct and the two answers are not in conflict, but they should not be conflated. A related point the paper now makes explicit (in its “which quantity answers which question” discussion, Section 9): the Fréchet–Hoeffding interval bounds the union probability *within the Pillar II seven-scenario decomposition at its central calibration*; it does *not* bound the Bayesian Layer IV percentiles, which integrate over parameter uncertainty as well. This is why the Layer IV 95th percentiles (16.5% and 17.4%) legitimately exceed the Fréchet–Hoeffding uppers (7.5% and 4.0%): the two quantities answer different questions, and the paper’s usage rule is to quote the Fréchet–Hoeffding interval for “what does the scenario model imply” and the Layer IV percentiles for “how bad could it be given everything we are uncertain about”. The Bayesian story is the empirically realistic model of correlated adversarial behaviour; the Fréchet lower bound is a mathematical bound, not a description of how dependence in real-world campaigns manifests. See **Independence Assumption** for further discussion of the two senses of “dependence”.

Inclusion–Exclusion Principle

A standard formula for the probability of a union of events in terms of the probabilities of their intersections. Used in the cut-set hazard aggregation of the attack graph.

Stochastic Dominance (First-Order)

Distribution *A* *first-order stochastically dominates* distribution *B* if *A* puts more probability on every “high” value than *B* does—equivalently, the cumulative distribution function of *A* lies entirely below that of *B*. The paper uses first-order stochastic dominance to make a structural claim: under the empirically grounded constraints that EA introduces (extra attack surface, extra targeting, extra concentration), the EA-equipped distribution stochastically dominates the no-EA one. This is a stronger statement than “the average is bigger”—it says the EA system is riskier *at every quantile*.

4.6 Sensitivity Analysis and Uncertainty Decomposition

Sensitivity Analysis

The exercise of varying one input parameter at a time (or jointly) and measuring the

consequence for the output. The paper reports both one-way (“tornado”) sensitivities and two-way grids. Sensitivity analysis is essential for distinguishing findings that depend critically on a single contestable assumption from findings that are robust across the plausible parameter space.

EVPPI (Expected Value of Partial Perfect Information)

A formal measure, borrowed from the health-economics literature, of how much output uncertainty would be eliminated if a single parameter (or group of parameters) were known exactly. EVPPI-style decomposition is the right tool for *research prioritisation*: it identifies the parameters whose better empirical characterisation would do the most to narrow the policy-relevant uncertainty.

Tornado Chart

A horizontal bar chart in which each bar shows the swing in the output as one input is varied across its plausible range. Bars are sorted by length, producing the tornado shape—and giving a visual read on which inputs matter most.

Spearman Rank Correlation

A correlation coefficient based on the *ranks* of the data rather than their values, robust to outliers and to non-linear monotonic relationships. Used in this paper as a consistency check between the model’s scenario ordering and the M-Trends technique-frequency ordering.

Complementary Cumulative Distribution Function (CCDF)

A plot of $\Pr(X > \tau)$ as a function of the threshold τ . CCDFs are the natural visualisation for tail-risk questions because the eye reads off “exceedance probability” directly. The paper uses CCDFs to compare the T-EA and OTT-EA distributions and to show the threshold at which the upper tails cross over: under the full dependence model the two distributions cross at approximately the 95th percentile of the annual compromise probability, below which T-EA is the stochastically riskier architecture and above which OTT-EA is. The crossover is the visual signature of the cross-architecture trade-off (see **Cross-Architecture Trade-Off**).

5 Modelling-Specific Concepts and Methodological Justifications

This part addresses the question that policy readers most often ask: *why these methods?*

Deep Uncertainty

A formal term, due to Lempert and others, for a state of knowledge in which we cannot agree on the *structure* of the probability distribution describing an unknown—let alone its parameters. Climate-change economics is the textbook setting. EA risk falls squarely in this regime: there is no historical record of EA-specific compromise events because no EA system has been deployed at the scale envisaged. Deep uncertainty does not mean nothing can be said; it means that the appropriate methodology is one that *makes the uncertainty explicit*, identifies findings robust across defensible assumptions, and equips decision-makers to act in the face of irreducible ignorance—rather than one that produces a single number with false precision.

Why this framing was chosen: Picking a single statistical method (say, Bayesian posterior inference against a specific dataset) would conceal the fact that no such dataset exists and that the headline number would depend almost entirely on the prior. Framing the problem as one of deep uncertainty forces the analysis to be transparent about which assumptions drive which conclusions.

The Three-Pillar Framework—and Why Three Pillars

The paper’s central methodological design is to attack the same question with three structurally

different approaches:

- **Pillar I—Historical Analogy.** Look at the actual historical compromise rates of systems that resemble EA in some important respect, and ask: how often have *they* been compromised?
- **Pillar II—Prospective Scenario Model.** Decompose the threat into a small set of attack scenarios, parameterise each from public empirical sources (EPSS, ATT&CK, DBIR), and propagate through a Monte Carlo simulation to produce a distribution of outcomes.
- **Pillar III—Architectural Heuristic.** Identify the components that any EA system must contain, take the best-in-class historical performance for each, and combine them into a “prudential benchmark”—answering the question “how good would such a system have to be just to match historical best practice?”

Why three: No single method is independently credible for a system that does not yet exist. Pillar I has direct empirical content but indirect architectural relevance. Pillar II has explicit architectural relevance but depends on parameter choices. Pillar III has structural force but depends on the independence assumption. Where the three pillars *agree*, that agreement is some evidence that the result is not an artefact of any one method’s particular flaws. Where they *disagree*, the disagreement itself is informative about which assumptions are doing the work. The paper is careful to acknowledge that the three pillars share an independence assumption, which is why the Bayesian Layer IV is added on top.

The Three Pillar I Streams (A, B, and C)

Pillar I draws empirical compromise rates from three architecturally distinct historical analogue cohorts, each anchoring a different architectural class:

- **Stream A** (50 government high-security analogues over 13 years): operations of HSM-protected key custodianship in high-classification environments. Anchors the T-EA case. Headline rate: 0.92%/yr per system at the primary inclusion criterion.
- **Stream B** (130 Certificate Authorities over 19 years): private-key compromises within a denominator-anchored CA cohort. Anchors the architectural bridge between T-EA and OTT-EA (the centralised single-operator class). Headline rate: 0.445%/yr per CA.
- **Stream C** (75 platform operators over 7 years): joint key-and-data compromise incidents at major platform providers (LastPass, Twilio Authy, Microsoft Storm-0558, JumpCloud, etc.). Anchors the OTT-EA case. Headline rate: 0.95%/yr per operator, using the architectural-fit-restricted strict-joint stratification (see Tier system entry).

The streams are deliberately disjoint by inclusion criterion. The paper does *not* pool all three into a single rate; each anchors its own architectural class, and only Streams A and B are pooled (as the centralised single-operator class) for the cross-stream meta-analysis.

Tier 0/1/2/3 Architectural-Fit Stratification (Stream C)

Stream C’s 14 incidents are stratified by how closely the operator’s architecture matches the OTT-EA reference model:

- **Tier 0 (gold standard, $k = 3$):** the operator was a documented custodian of cryptographic key material or 2FA seeds at rest, and the compromise involved exfiltration of that material *together with* the segregated user data it protected. Examples: LastPass, Twilio Authy, Microsoft Storm-0558.
- **Tier 1 (interpretive key custody, $k = 2$):** the operator’s role as key custodian required interpretation (directory-service infrastructure or supply-chain mediated key acquisition). Examples: Codecov, JumpCloud.

- **Tier 2 (looser architectural fit, $k = 7$):** the OTT-EA mapping is partial (e.g. session-token-equivalent rather than cryptographic key material). Examples: Okta, MOVEit, Microsoft Midnight Blizzard.
- **Tier 3 (sensitivity only, $k = 2$):** included only to test robustness. Examples: Slack, Snowflake/AT&T.

The headline rate (0.95%/yr) uses the Tier 0+1 strict-joint stratification. Tier 0 alone gives a very-conservative lower bracket (0.57%/yr); the all-tiers $J = Y$ rate gives an upper bracket (1.33%/yr). The qualitative ordering Stream B < Stream A $\approx$ Stream C, all on the order of 1%/yr, is robust across the full stratification range.

Near-Miss Exclusion

A methodological principle for the Stream C cohort: incidents where the attacker reached cross-cutting infrastructure but did *not* exfiltrate customer data or service keys are documented as “near-misses” rather than counted in the rate calculation. The canonical example is Cloudflare 2023 (Atlassian-mediated APT detected within hours, no customer data accessed, no service keys compromised). Including such incidents at full weight would assign positive analogical force to events that did not actually involve operational compromise of the relevant assets; including them at fractional weight requires a contestable weight assignment. Excluding them (weight zero) is the conservative choice for a rate-estimation purpose because it biases the headline rate downward.

Strict-Joint vs Inclusive-Joint Classification

A Stream C classification dimension. An incident is classified *joint key-and-data compromise* as $J = Y$ (strict) only if documented evidence shows operational sufficiency for OTT-EA-style decryption: the attacker obtained both key material *and* the data it protected at a level usable to recover plaintext. Incidents where joint compromise is interpretive or partial are classified $J = P$. The paper’s headline rate uses $J = Y$ strict only; an inclusive classification ($J \in \{Y, P\}$) yields a higher rate of 2.48%/yr at all tiers and is reported as an upper bracket. The strict classification is preferred for headline use because it counts only incidents where the analogy to OTT-EA decryption is unambiguous.

The Bayesian Structural Risk Model (Layer IV)—and Why a Fourth Layer

The three pillars together produce assumption-conditional point estimates. Layer IV does five things they cannot:

1. It replaces point estimates with *distributions*, so that uncertainty propagates honestly through to the output. The architecture-conditional distributional shape (heavy-tailed for both T-EA and OTT-EA, conditionally heavier for OTT-EA) is then read off the prior predictive output.
2. It explicitly *models dependence* between attack channels via the latent campaign variable $Z(t)$, so that the paper can quantify how optimistic the independence assumption is. The dependence quantification is divergent across architectures: campaign correlation inflates the annual 95th percentile by $\times 1.53$ for T-EA and $\times 2.83$ for OTT-EA.
3. It identifies *cross-cutting infrastructure* as the structural mechanism through which correlated campaigns erode the OTT-EA segregation gain. This is the OTT-EA-specific architectural finding the three-pillar framework cannot deliver.
4. It supports *exceedance probability* questions of the form “what is the probability that the true annual risk exceeds 1%?”, which are often more useful for policy than point estimates.
5. It produces a *parameter uncertainty decomposition* identifying which parameters’ better empirical characterisation would most reduce output uncertainty—a research-prioritisation signal that is architecture-specific (for OTT-EA the cross-cutting coupling ratio and the

segregation factor enter as additional dominant variance sources).

Why a Bayesian framework rather than something else: The Bayesian formalism is the natural language for representing structured uncertainty about parameters. A non-Bayesian approach would either commit to point estimates (and lose the uncertainty) or produce confidence intervals that, as noted above, do not admit the natural probabilistic interpretation that policy readers expect.

Domain Transfer

The formal apparatus by which information from a non-EA system is mapped onto a hypothetical EA system. The paper expresses this as a transport function with explicit, signed adjustment factors for each architectural dimension on which the analogue and the target differ. Domain transfer makes the analogical reasoning auditable: a sceptical reader can see exactly which adjustments were applied and challenge them individually. The revised paper applies domain transfer *architecture-conditionally*: T-EA priors are calibrated from Streams A and B (government high-security systems and the CA cohort, both architecturally close to centralised single-operator key custody with co-located data), while OTT-EA priors are calibrated from Streams B and C (the CA cohort as architectural bridge, plus the platform-level key/data compromise cohort, which is the most analogically direct mapping in the paper—Stream C incidents are themselves drawn from the architectural class to which OTT-EA belongs, modulo the absence of an EA mandate).

EA Targeting Premium

A multiplicative factor expressing the increase in adversarial attention that EA infrastructure attracts above and beyond a non-EA baseline. The paper now derives a *structured judgement range* of $3\times$ – $15\times$ rather than asserting a single value—a range constructed by the author from named anchors and labelled as such, not the output of a formal multi-expert elicitation protocol—motivated by the Salt Typhoon and Athens precedents, the sector-resolved state-actor share in the DBIR actor-mix data, and the qualitative disparity in documented targeting of cryptographic-infrastructure assets (consistent with a multiplier of at least 3 – $5\times$). The $10\times$ value used in headline projections sits in the upper-mid of that range; $5\times$ and $15\times$ projections are reported alongside it. The targeting premium remains the most important and most contestable single assumption in the paper—and, as the falsifiable-implications section notes, the parameter the framework most expects future evidence to revise—which is why it is exposed as a sensitivity parameter throughout.

Attack Surface Modifier (δ_{EA})

A multiplier capturing the increase in attack surface introduced by an EA mechanism above and beyond the non-EA baseline. Any EA architecture necessarily adds codebase, interfaces, and key-management components beyond those present in the corresponding non-EA system, so $\delta_{\text{EA}} \geq 1$ holds by structural argument rather than calibration. Together with the targeting premium δ_{target} and the concentration premium δ_{concen} , this is one of the three system modifiers whose joint lower bound at unity grounds Proposition 1 (the stochastic dominance result).

Concentration Premium (δ_{concen})

A multiplier capturing the fact that an EA system aggregates the keys of an entire user population in one place, raising the value of the target. The OTT-EA concentration premium is intrinsically larger than the T-EA one because OTT platforms typically serve hundreds of millions to billions of users.

Campaign Amplification (γ , γ_X , and the ratio γ_X/γ)

The mathematical knob through which the latent campaign intensity $Z(t)$ couples into the

edge hazard rates. For T-EA, a single γ multiplies Z 's effect uniformly across all edges. For OTT-EA, a *separate* and larger γ_X multiplies its effect on cross-cutting edges, formalising the architectural argument that correlated campaigns preferentially exploit shared infrastructure. The ratio γ_X/γ is the central architectural-divergence parameter and the dominant source of OTT-EA tail risk; the paper's primary calibration centres the prior on 2 (log-normal, scale $\sigma = 0.40$ at the headline), with a median-multiplier sensitivity sweep reported over ratios $\{1.2, 1.5, 2, 3, 4\}$: the OTT-EA tail uplift grows monotonically from $\times 1.73$ at ratio 1.2, through the headline $\times 2.83$ at ratio 2, to $\times 6.22$ at ratio 3 and $\times 12.4$ at ratio 4. As the ratio approaches 1 the OTT-EA dependence response collapses to the T-EA case, matching T-EA's $\times 1.53$ to within rounding (consistency check). The qualitative finding that cross-cutting coupling inflates the OTT-EA tail relative to T-EA holds across the full range.

Segregation Factor ($P_3 \cdot P_4$)

The product of two probabilities that together describe how effectively architectural segregation actually protects against joint compromise: P_3 is the conditional probability that an attacker who has obtained keys can also reach the encrypted-data store; P_4 is the conditional probability of completing the operation without detection. Their product, set at 0.30 in the primary calibration with sensitivity over $[0.12, 0.64]$, is the single most influential OTT-EA parameter—which is why the EVPPI analysis flags its empirical characterisation as a first-order research priority.

Cross-Cutting Fraction (ξ)

The proportion of attacks within a given channel that traverse cross-cutting infrastructure, bypassing the segregation. ξ values are calibrated per scenario and per channel against the Stream C incident base, anchored on the empirical cross-cutting fraction $\hat{p}_X = 7/14 = 0.50$ (seven of the fourteen Stream C incidents traversed cross-cutting infrastructure).

Heuristic Floor vs Structural Lower Bound

The paper is careful to distinguish a *heuristic floor* (the minimum value that follows under stated and contestable assumptions, such as four-channel exhaustiveness) from a *structural lower bound* (a value below which the risk cannot mathematically fall, regardless of assumptions). The 1.5% T-EA “floor” is a heuristic, not a structural bound: if there are additional risk channels beyond the four enumerated, the true floor is higher.

Prudential Benchmark Estimate

A specific term of art the paper uses for the Pillar III headline number. It is *not* a measurement and *not* a structural lower bound—it is the answer to the conditional question “if every component performs at the historical best-in-class level, and if the components fail independently, what combined risk follows?” Naming it “prudential” rather than “predicted” signals that it is meant as a baseline for risk-management decisions, not as a forecast.

Counterfactual

The hypothetical world in which the EA mandate is *not* imposed. Many of the paper's claims are explicitly comparative to the no-EA counterfactual rather than absolute: the stochastic dominance result, for example, says that the EA-configured architecture is riskier *than the same architecture without the EA modifiers*.

Structural Ordering

The paper's term of art for its most assumption-robust finding: that EA-equipped architectures carry strictly higher modelled compromise risk than the same architecture without EA modifiers. “Structural” because the claim does not depend on the magnitude of any particular parameter (the targeting premium, the concentration multiplier, the segregation factor, the dependence structure) but only on their *signs*, which are empirically constrained. The paper is explicit about the logical type of its formal proposition: the mathematics is deliberately

slight once the modifier bounds are granted, and the substance is the empirical case for the bounds—so a critic must identify which modifier could credibly fall below one, and for which architecture. “Ordering” because the formal expression of the claim is a first-order stochastic dominance result (see **Stochastic Dominance (First-Order)**): the EA-configured risk distribution puts more probability on every high-risk outcome than the no-EA counterfactual (see **Counterfactual**) does, so the EA system is riskier *at every quantile* rather than only on average. The paper labels this S1 in its synthesis hierarchy (see **Synthesis Hierarchy (S1–S6)**) and treats all other quantitative findings as conditional on additional assumptions whose relaxation could in principle change the magnitude—but not the direction—of the EA risk effect.

Synthesis Hierarchy (S1–S6)

The paper’s six-tier ranking of its findings by robustness to assumption variation, used throughout to signal which conclusions can bear policy weight on their own and which require additional caveats. Lower numbers indicate greater assumption-stability:

- **S1.** The structural ordering: EA-equipped architectures carry strictly higher modelled risk than the no-EA counterfactual, within each architectural class. Survives any defensible parameter choice.
- **S2.** The distributional tail finding: under primary and conservative prior calibrations, the annual compromise distributions of both architectures are heavy-tailed (Fréchet domain), and campaign-dependence modelling inflates the upper tail by an architecture-dependent factor. Prior-conditional but stable at plausible calibrations.
- **S3.** The exceedance finding: under the primary calibration the probability that annual risk exceeds 1% is high for both architectures. Prior-conditional; falls below 0.5 for OTT-EA under the conservative prior, but the architectural ordering is preserved.
- **S4.** The empirical anchors and the Fréchet–Hoeffding intervals: Pillar I per-system rates and the model-consistent intervals [2.2%, 7.5%] (T-EA) and [1.1%, 4.0%] (OTT-EA). Bounded by data and model structure respectively.
- **S5.** The independence-conditional point estimates: the 5.4% (T-EA) and 3.0% (OTT-EA) prudential benchmarks and the 7.3% / 3.9% Pillar II centrals. Most exposed to dependence structure and the least robust class of findings.
- **S6.** The cross-architecture trade-off (see **Cross-Architecture Trade-Off**). Structural rather than parameter-dependent; among the more reliable findings.

The framework’s headline qualitative finding—that EA compromise risk is material across the defensible range—rests on S1–S4 and S6, not on S5. When the 5.4% number appears in policy summaries, it should be read as illustrative of the independence-conditional benchmark class, not as the paper’s central robust result.

Three Classes of Findings (Structural vs Calibration-Dependent)

The revised paper opens its synthesis (Section 10) by sorting its findings into three classes—a coarser view of the same S1–S6 hierarchy. *Class one* follows from architecture alone and survives any defensible calibration: the dominance ordering, the Fréchet–Hoeffding interval logic, and the *direction* of the OTT-EA tail divergence. *Class two* holds across the full calibration set examined (primary, conservative, and pessimistic priors) but is not derivable from structure alone: material multi-decade cumulative risk, the preservation of the T-EA-over-OTT-EA central ordering, and the low-threshold exceedance ordering. *Class three* is calibration-dependent and should be quoted only with its calibration attached: specific medians, percentiles, and tail magnitudes. The paper exhibits its own falsification case honestly: under the pessimistic tail calibration one headline tail comparison changes sign, which is precisely why the class boundaries matter.

Falsifiable Implications

A section the revised paper adds (within the policy discussion, Section 12) committing the framework to predictions that future evidence can confirm or refute. Three commitments: (i) a forward prediction from Stream B—at the fitted CA compromise rate, the 2025–2030 window (roughly 780 CA-operator-years) should produce a mean of 3.5 disclosed incidents with 95% predictive interval $[0, 8]$; a zero-incident six-year run (predictive probability $\approx 4.9\%$) would warrant revising the centralised-operator anchor downward, and a count above eight the converse; (ii) an update rule for deployed systems—ten system-years of clean operating history carries a likelihood ratio of about 1.5 favouring the $3\times$ over the $10\times$ targeting premium, so the premium is explicitly revisable by experience rather than fixed doctrine; and (iii) the prediction that correlated campaigns will preferentially traverse cross-cutting infrastructure, testable against the incident record as it accumulates. The point of the section is methodological honesty: a framework that can be wrong in stated ways is one whose claims can be trusted in proportion to their survival.

Cross-Architecture Trade-Off

The substantive finding (stated as a formal Remark in the paper) that the comparison *between* T-EA and OTT-EA is *not* first-order stochastic dominance. Under the central calibration the T-EA distribution lies above the OTT-EA distribution at the median (T-EA is riskier on average), but the OTT-EA distribution exceeds the T-EA distribution in the upper tail under correlated-campaign conditions, because the cross-cutting coupling erodes the segregation gain precisely in the worst-case scenarios. Under the full dependence model the two distributions cross at approximately the 95th percentile of the annual compromise probability. The policy implication, made explicit in the results, synthesis, and policy sections (Sections 9, 10, and 12), is that architectural choice between T-EA and OTT-EA cannot be reduced to a single quantile: it is an expected-risk-versus-tail-risk trade-off, and on the criteria policymakers conventionally apply to catastrophic systems (tail probability and tail consequence) OTT-EA is the less defensible of the two despite its lower median.

Irreversibility Asymmetry

A policy concept rather than a statistical one: the observation that the *benefits* of EA accrue period-by-period and stop if the mandate is withdrawn, whereas the *costs* of a key-material compromise are permanent—once exfiltrated, all historical traffic protected under that key becomes retrospectively decryptable. Standard expected-value analysis treats gains and losses symmetrically; the paper notes that this is inappropriate for EA, where the loss tail is irreversible.

Weakest-Operator Problem

The observation that EA mandates apply to *all* qualifying operators in a jurisdiction, so the systemic risk profile is determined by the *least well-resourced* operator, not the best. A policy framework calibrated against tier-one operator security cannot legitimately ignore the long tail of weaker operators that the same mandate would cover.

Reproducibility and Seed Stability

The paper uses fixed random seeds (2024 by default, with stability checks at 3024, 4024, 5024) so that any reader can re-run the simulations and obtain identical numbers. The seed-stability check also confirms that the headline figures are not artefacts of one particular sequence of random numbers—across the four seeds, T-EA medians vary by less than 0.2 percentage points.

What the Paper Finds, in Plain English

This section summarises the paper’s principal findings without the mathematics. The intent is to give a policy reader who has skimmed the glossary a single self-contained statement of what the analysis actually concludes. All findings are conditional on assumptions that the paper makes explicit; here the assumptions are pointed to but not restated.

1. EA-equipped architectures are riskier than no-EA counterfactuals

Across all defensible parameter choices, an architecture with EA modifiers applied carries strictly higher modelled compromise risk than the same architecture without those modifiers. This is the most assumption-robust finding in the paper. It does not depend on a particular targeting premium, a particular concentration multiplier, or a particular dependence structure. It is a statement about the *direction* of the EA effect, not about its magnitude.

2. The central tendency cluster is in the low single digits

The paper’s three independent methodological approaches converge on a narrow range of central annual compromise probabilities:

- For T-EA: a Pillar II central of 7.3%, a Pillar III prudential benchmark of 5.4%, a Bayesian median of 4.0%, and a heuristic floor of 1.5%.
- For OTT-EA: a Pillar II central of 3.9%, a Pillar III prudential benchmark of 3.0%, a Bayesian median of 2.6%, and a heuristic floor of 1.0%.

The model-based central values for OTT-EA sit at approximately half the corresponding T-EA values across all three pillar methodologies. (The empirical analogue rates in Pillar I do not show the same pattern: the OTT-leaning analogue rate is in fact higher than the T-EA-leaning rate. The Pillar II and Pillar III models reduce OTT-EA below T-EA *despite* this, by accounting for architectural segregation.)

3. The tails are heavy, and OTT-EA’s tail is heavier

Both architectural distributions place non-negligible probability mass above any plausible policy acceptability threshold, and both have heavier-than-exponential tails (positive GPD shape parameter: $\hat{\xi} = 0.271$ T-EA; $\hat{\xi} = 0.518$ OTT-EA, with non-overlapping bootstrap intervals). Under the full dependence model the two distributions cross near the 95th percentile of the annual compromise probability (16.5% vs 17.4%); beyond it OTT-EA pulls sharply away, reaching 58.9% at the 99th percentile against T-EA’s 35.2%—a gap of more than twenty percentage points. The architectural segregation that produces OTT-EA’s lower median is largely erased at the tail.

4. The cost of assuming independence is sizeable

The Pillar I, Pillar II, and Pillar III calculations all share an independence assumption between attack channels. The Bayesian Layer IV relaxes that assumption and quantifies the consequences. Correlated adversarial campaigns inflate the annual 95th percentile by $\times 1.53$ for T-EA and $\times 2.83$ for OTT-EA, and raise the median ten-year cumulative compromise probability from 26.6% to 36.6% (T-EA) and from 15.7% to 31.9% (OTT-EA). The OTT-EA inflation is larger because correlated campaigns preferentially exploit the cross-cutting infrastructure (signing keys, identity providers, platform vendors) that defines OTT-style architectures.

5. The probability of a materially bad outcome is high

Under the primary prior calibration the probability that the true annual compromise rate exceeds 1% is 0.988 for T-EA and 0.907 for OTT-EA. Under a conservative prior calibrated to assume substantial defensive overperformance, the exceedance probability falls below 0.5 for OTT-EA (to 0.460) but stays above 0.5 for T-EA (at 0.605). The exceedance findings are thus prior-conditional but the architectural ordering is preserved across the calibrated range.

6. Compounding shrinks the defensible deployment horizon

At a 5% cumulative-risk acceptability threshold over a multi-year horizon, the maximum defensible deployment is about two years for both architectures. At a 10% threshold the horizons are three (T-EA) and four (OTT-EA) years; at 20%, six and nine; at 30%, nine and fourteen; and at 50% the gap widens to 17 years T-EA versus 26 years OTT-EA at the median. The OTT-EA central horizon is longer, but its distribution is tail-heavier, so high-cumulative-risk outcomes remain more plausible for OTT-EA at every horizon. The apparent OTT-EA central-horizon advantage is therefore offset by greater uncertainty about how long is actually defensible.

7. Architectural mitigations are first-order, not supplementary

Threshold cryptography schemes (where compromise of any individual custodian is insufficient and a quorum is required to reconstruct a key) reduce annual compromise risk by roughly an order of magnitude within the model. They do not eliminate the risk, but they remove the single-point-of-failure that drives the heavy-tailed behaviour of both architectural classes. Architectural choices that reduce cross-cutting coupling more generally—of which threshold schemes are one example—change the risk profile by more than the choice between T-EA and OTT-EA does. Conversely, hybrid client-side scanning (CSS) architectures move in the opposite direction: they enlarge the cross-cutting attack surface still further by adding endpoint-distributed detection keys whose security is governed by mobile-platform properties the paper’s empirical anchors do not cover. The precautionary policy posture is to treat CSS as carrying at least the OTT-EA risk profile, with material additional risk from the endpoint-distribution component.

8. What the paper does not claim

The paper does not produce a single defensible point estimate; it argues that no such estimate is available. The paper does not demonstrate that any specific compromise rate *will* occur; its projections are conditional on assumptions made explicit throughout. The paper does not assert that EA mandates should never be considered; it argues that the evidentiary bar for any specific mandate is higher than the central-tendency comparison alone would suggest, and that the appropriate framing is catastrophic-risk policy rather than expected-value cost-benefit analysis. Most importantly, the paper does not claim that OTT-EA is uniformly an improvement over T-EA: on the central tendency it is, but on the two dimensions that matter for catastrophic-risk policy—tail probability and consequence given compromise—it is not.

A Final Note on How to Read the Numbers

The paper reports many numbers, and they are not all of the same kind. A useful reading discipline:

- **Empirical anchors** (Stream A 0.92%/yr, Stream B 0.445%/yr, Stream C 0.95%/yr, and the pooled centralised single-operator rate of 0.545%/yr) are *measurements* of historical analogue rates. They have confidence intervals, but they are not projections of EA risk.
- **Targeting-premium projections** (1.4–12.9% annually for T-EA across the structured-

judgement $3\times-15\times$ premium range; 2.8–4.7% for OTT-EA under independence after the segregation adjustment) are the empirical anchors propagated through an explicit but *contestable* multiplier. The width of the range is the honest representation of the targeting-premium uncertainty.

- **Independence-conditional benchmarks** (the 5.4% T-EA and 3.0% OTT-EA prudential figures) are *what would follow* under the independence assumption. They are not robust to correlated campaigns and the paper says so explicitly.
- **Fréchet–Hoeffding intervals** ([2.2%, 7.5%] for T-EA; [1.1%, 4.0%] for OTT-EA) are the *model-consistent* ranges under any dependence structure within the model’s seven-scenario decomposition at its central calibration. The paper recommends these for policy use over any single point estimate—while noting that they bound the scenario model, not the Layer IV distributional output.
- **Bayesian prior predictive intervals** ([1.4%, 16.5%] for T-EA; [0.8%, 17.4%] for OTT-EA) are full distributional uncertainty under the calibrated priors—prior predictive rather than posterior, since no EA-specific data exist to update against. They are wide because the underlying uncertainty is wide; this is a feature of the analysis, not a bug. Their 95th percentiles legitimately exceed the Fréchet–Hoeffding uppers because the two quantities answer different questions (Section 9 of the paper).
- **Dependence inflation factors** ($\times 1.53$ T-EA and $\times 2.83$ OTT-EA on the annual 95th percentile, with the median ten-year cumulative probability rising from 26.6% to 36.6% and from 15.7% to 31.9% respectively) are the multipliers by which the upper tail expands when correlated-campaign behaviour is modelled rather than assumed away. These are robust ratios within the calibrated prior, not contestable extrapolations: they characterise the cost of the independence assumption that Pillars I–III all share. Note that the Fréchet–Hoeffding lower bounds (2.2% T-EA; 1.1% OTT-EA) and the Bayesian dependence inflation factors answer different questions and should not be netted against one another: the former bounds the union of events at fixed individual probabilities, the latter quantifies what happens when campaign intensity raises all hazard rates simultaneously. The latter is the empirically realistic story of correlated adversarial behaviour; the former is a model-internal bound. See the **Independence Assumption** entry for the full disambiguation.

The paper’s most assumption-robust qualitative claim is not any single percentage but the *structural ordering*: under empirically grounded constraints, EA-equipped architectures of either class carry strictly higher risk than the same architecture without EA. The quantitative magnitude is a matter of legitimate debate; the *direction* is not.